

Módulo 1. Políticas, planes y procedimientos de seguridad

Introducción

El objetivo de esta materia es que seas capaz de identificar aspectos básicos y conceptuales de la seguridad de la información. Además, aprenderás sobre diferentes políticas y procedimientos de seguridad utilizados a nivel mundial, con la finalidad de confeccionar la documentación necesaria para comenzar a gestionar la seguridad de la información de las organizaciones.

Como profesional técnico en seguridad de la información, deberás aplicar políticas y procedimientos para proteger activos, gestionar incidentes y contribuir a la implementación de controles conforme a marcos internacionales como la ISO/IEC 27001.

Una vez obtenidos estos conocimientos estarás capacitado para desarrollar tus tareas como profesional.

En este módulo, conoceremos diferentes actividades, políticas, planes y procedimientos para la gestión de la seguridad de la información en una organización, introduciendo desde el punto de vista conceptual hasta la confección de documentación necesaria para efectuar labores de gestión y administración de la seguridad. Aprenderemos sobre los principios de seguridad, objetivos de negocio, procesos críticos, estándares y procedimientos, para luego profundizar en detalle sobre políticas de seguridad para el personal y los procesos asociados a esta, dando un énfasis a la educación y la privacidad.

Video de inmersión

Unidad 1. Establecer políticas de seguridad

Tema 1. Principios de seguridad de la información: confidencialidad, integridad y disponibilidad

Las TIC (tecnologías de la información y la comunicación) y especialmente la informática, están alojadas en todos los entornos de la sociedad: desde la prensa hasta la educación, siendo cada vez más beneficiosas e indispensables para el desarrollo de las actividades diarias. Antiguamente, para realizar una transacción bancaria, era necesario desplazarse físicamente a la sucursal de banco más cercana. En la actualidad, es posible hacer una transferencia en solo 5 segundos desde el teléfono móvil y, lo fabuloso es que, se puede realizar desde cualquier parte del planeta; reduciendo tiempo, riesgos y recursos.

De igual forma que crece el uso de la informática, la seguridad informática debe tener una relevancia cada vez mayor, considerando que el funcionamiento correcto de sus sistemas nos brindará una mejor protección de nuestros datos. A pesar de ello, aún si se reducen riesgos, no estamos exentos de ser víctimas de algún delito digital.

Todos estamos inmersos en esta era tecnológica, pero la pregunta es: ¿tú crees que estamos prevenidos para evitar el robo de información digital que viaja en internet, como: contraseñas, tarjetas de crédito, entre otros?

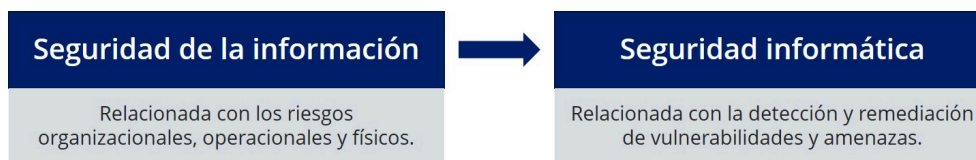
Durante el avance del módulo, visualizaremos que las amenazas, medidas de protección y vulnerabilidades han ido en aumento y cambiando sus variantes con el tiempo. Para ello haremos uso de conceptos básicos de seguridad de datos, comenzando a entender los tres principios de la seguridad de la información (confidencialidad, integridad y disponibilidad) y cuál es su objetivo principal. Finalizaremos identificando los factores accidentales e intenciones de error, teniendo en cuenta las amenazas latentes en la actualidad como: phishing, ingeniería social, ataques de denegación de servicio, malware, entre otros.

Desde este punto queremos convertirte en el profesional que controle la seguridad al interior de la organización. ¿Preparado?

Seguridad informática vs. seguridad de la información

Junto con el desarrollo y la evolución de la tecnología, crecieron las diferentes vulnerabilidades que afectan los datos privados y aumentaron los delitos informáticos. Ello conlleva a tener presente dos conceptos claves en el ámbito de seguridad informática, que en un principio pueden parecer similares. Sin embargo, son conceptos que se deben trabajar siempre en forma conjunta.

Figura 1: Conceptos claves



Fuente: elaboración propia.

Es importante distinguir entre ambas disciplinas ya que cada una de ellas tiene objetivos diferentes a proteger. A tener en cuenta: cuando hablamos de seguridad informática, debemos considerar diferentes aspectos técnicos para la protección de los activos valiosos de la organización, mientras que por el lado de la seguridad de la información podríamos definir toda actividad o gestión que permitirán la ejecución de tareas técnicas.

Seguridad informática

La seguridad informática busca asegurar que todos los recursos utilizados en sistemas de información —es decir, material informático o programas de una organización— sean utilizados para lo cual fueron creados o implementados y que el acceso a la información almacenada, así como su modificación o manipulación, solo sea posible por las personas debidamente autorizadas.

También podemos decir que es el proceso de protección de los recursos informáticos contra intrusiones con propósitos maliciosos en nuestra red. Sabemos que en la actualidad no hay sistemas 100 % seguros, pero fortaleciéndonos continuamente con buenas prácticas de seguridad podemos reducir los riesgos.

Entre las buenas prácticas más importantes se recomiendan las siguientes .

≡ Inventario real y actualizado

de todo el equipamiento informático, dispositivos en la red, documentación, como por ejemplo, políticas de seguridad, de control de acceso, etcétera.

≡ Concientización al personal interno

sobre los riesgos actuales en el ámbito de seguridad informática, en especial para quienes no trabajan directamente con el área de la seguridad.

≡ Implementación de dispositivos de seguridad perimetral

como, por ejemplo, un *firewall* o cortafuegos, *hardware* o *software* que tiene por misión filtrar el tráfico para prevenir contenido malicioso.

≡ Continúo análisis

de todo activo informático, dispositivos en la red y sistemas utilizados por proveedores o clientes, con la finalidad de detectar vulnerabilidades y/o amenazas.

≡ *Backups*

llevar a cabo periódicamente **copias de seguridad** de todas las configuraciones de equipos, códigos de fuente, y datos críticos de la institución.

La única finalidad de la seguridad informática es prevenir y detectar el uso no autorizado de los sistemas informáticos con la ayuda de la implementación, administración y monitoreo de procedimientos técnicos que involucren al *hardware* o el *software* en una empresa. Cabe señalar que, de este concepto, nace la noción de seguridad perimetral.

De lo comentado anteriormente, existen componentes de los cuales escucharán siempre, primero el antivirus y luego el dispositivo *firewall*. Ambos componentes tienen como finalidad proteger los sistemas informáticos de una organización, por lo tanto, pertenecen al ámbito de la seguridad informática.

En una organización pequeña, mediana o grande, las computadoras obligatoriamente deben contar con un antivirus que ayude a detectar y bloquear software malintencionado en los computadores. Si la misma organización tiene equipos servidores donde aloja información – además de servicios como correo electrónico, servidor de carpetas compartidas y servidores web, entre otros– estos equipos al encontrarse en una misma red necesitan un dispositivo de seguridad perimetral (*firewall*) que ayude a bloquear y proteger las conexiones entrantes o salientes en la red.

Reforzando el concepto de Firewall, este puede definirse como

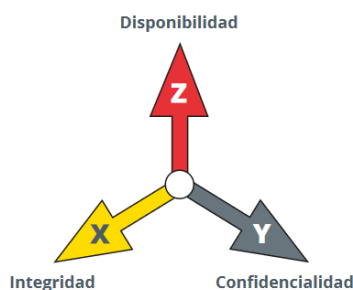
un software especializado que se interpone entre las aplicaciones y el software de red para **hacer un filtrado de paquetes**.

- En el **tráfico entrante**, la tarjeta de red recibe el paquete y lo identifica, pero antes de entregarlo a la aplicación correspondiente, pasa por el firewall para que decida si prospera o no.
- En el **tráfico saliente**, las aplicaciones elaboran sus paquetes de datos, pero antes de entregarlo al software de red para que lo envíe, pasa por el firewall. (“Seguridad Activa – Control de Redes”, 2016, <https://bit.ly/3EQbQ7A>)

Tríada de seguridad

Los expertos en seguridad informática están analizando permanentemente las vulnerabilidades y amenazas actuales, fundamentándose en el impacto que tienen sobre los activos de una organización. Tomando como referencia esa evaluación, se ejecutan varios controles de seguridad para mitigar el riesgo que producen. Para lograr entender qué es lo que se intenta proteger, existe la denominada “tríada”, muy importante en el ámbito de la seguridad de la informática. Si te atacan un sistema, se produce una clonación de alguna de tus tarjetas de crédito, te atacan un sitio web u otro incidente de seguridad, podrías identificar de forma clara que uno de estos pilares ha sido vulnerado. Cuando se habla de la tríada de la seguridad se hace referencia a los tres pilares o componentes esenciales de la seguridad, nos referimos a la confidencialidad, la integridad y la disponibilidad, que también se le conoce como el triángulo de la seguridad.

Figura 2: Tríada de la seguridad



Fuente: Incibe, s. f., p. 6.

Confidencialidad

Su objetivo es que la información que viaja por la red sea confidencial y esta no sea capturada o divulgada a personas u organizaciones que no estén autorizadas.

Los ataques más frecuentes contra la confidencialidad son:

Los sniffers de red: Estos programas capturan todo el tráfico que circula por una red. Toda información que no se encuentre cifrada, será conocida por el atacante.

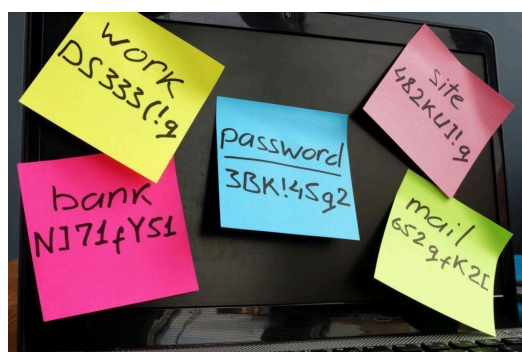
...El acceso no autorizado a archivos: Cuando no existe o está mal configurado el control de acceso a los recursos, personas no autorizadas podrán acceder a los datos.

...El acceso remoto no autorizado a base de datos: A menudo, los atacantes explotan errores de configuración en el control de acceso a la base de datos o fallos en las aplicaciones que actúan de interfaz entre el usuario y la base de datos. El resultado final es el acceso indiscriminado a la información confidencial almacenada. (Álvarez Marañón y Pérez García, 2004, p. 95)

Para evitar estos ataques, se recomienda usar herramientas como: el cifrado de archivos, el sistema de cifrado de Windows, el cifrado de discos duros, el cifrado de datos en el navegador a través de SSL, la esteganografía –que es el estudio y aplicación de técnicas que permiten ocultar mensajes u objetos dentro de otros–, etcétera.

La confidencialidad trata de que la información no sea revelada a usuarios no autorizados, los atacantes pueden frustrar la confidencialidad, haciendo Shoulder Surfing, robo de contraseñas, romper sistemas de encriptación e ingeniería Social. Shoulder Surfing, trata de mirar sobre el hombro de alguien, para ver cuáles son las teclas que presiona al ingresar una contraseña o mirar algún papel o archivo que contenga la contraseña de ingreso a un sistema. Cabe destacar que muchas personas dejan la contraseña escrita en algún papel pegado al monitor o escrito en un cuaderno a vista de todo el mundo. (Cortes Robles, 2016, <https://bit.ly/31zBkrH>)

Figura 3: Contraseñas



Dentro de la confidencialidad, la información que se envía en un ambiente cliente-servidor, debe estar encriptada ya que la información puede ser robada y mal utilizada como por ejemplo: ver la información de una cuenta bancaria.

[Para obtener este tipo de datos existen diversas técnicas o disciplinas, una de las más utilizadas es] La ingeniería social puede lograr obtener información induciendo a una persona a realizar acciones para poder obtener la información que se necesita.

Algunos tips para la confidencialidad es la siguiente:

- Encriptar la data enviada y la respuesta (TLS 2.0,).
- Encriptar Discos y bases de datos.
- Encriptar la data en tránsito (SSL, IPSEC, PPTP, en pocas palabras VPN).
(Cortes Robles, 2016, <https://bit.ly/31zBkrH>)

Integridad

El segundo pilar hace referencia a la integridad que, siguiendo a Cortes Robles (2016), nos indica que la información debe ser la misma desde su origen hasta el consumidor o receptor final. Por lo tanto, no puede ni debería ser alterada en ningún momento durante la transmisión, por ejemplo, desde un cliente a un servidor. La integridad puede verse afectada por el accionar de terceros, desde un atacante “profesional” hasta el descuido por parte de un administrador de plataforma tecnológica. A su vez, esta puede verse comprometida también por errores humanos, tanto accidentales como intencionales. En resumen, una modificación de la información, por más mínima que sea, puede convertirse en pérdidas de activos dentro del negocio o remediaciones costosas para la organización.

Para ejemplificar mejor esto, “las modificaciones accidentales puede ser información errónea ingresada en una base de datos [por desconocimiento o descuido], o puede ser usos de *backdoor* o SQL Injection haciendo modificación no autorizada y mal intencionada de las bases de datos” (Cortes Robles, 2016, <https://bit.ly/31zBkrH>).

Algunos ejemplos que nos permiten identificar o mantener integridad pueden ser:

- Hashing
- Control de Acceso
- Gestión de Privilegios

- RFC y Gestión de Cambios
- Gestión de Configuraciones
- Firmas Digitales
- Funciones de CRC

Dentro de los ataques que están contra la Integridad tenemos:

- Robo de Sesión
- SQL Injection
- Inyección de Código
- Elevación de privilegios. (Cortes Robles, 2016, <https://bit.ly/31zBkrH>)

Disponibilidad

El objetivo principal de este pilar de la seguridad es asegurar que los datos y sistemas estén disponibles siempre para los usuarios o en el momento que lo requieran.

Una fiscalización permanente es importante para asegurar una correcta disponibilidad de los sistemas y servicios. La disponibilidad exige que se implementen una serie de controles para asegurar un nivel razonable de rendimiento, una gestión rápida y eficiente de las interrupciones, proporcionar redundancia en caso de fallos, mantener copias de seguridad actualizadas y evitar la pérdida o destrucción de datos.

En una empresa,

existen varios dispositivos o sistemas que deben de estar disponibles para el acceso a la información, como por ejemplo, router, DNS, Firewall, IDS, DHCP, Servidores, software, etc. Existen varios riesgos que atacan contra la disponibilidad, como por ejemplo, inundaciones, incendios, terremotos, cualquier tipo de desastre natural, o alguna debilidad de acceso a los componentes del sistema que pueda llegarse a tocar de manera accidental o de manera intencional.

Dentro de la disponibilidad existen los siguientes tips para cumplirlas:

- RAID
- Clúster, de servidores
- Balanceo de Carga
- Redundancias ...eléctricas
- Alta Disponibilidad de red

- Discos Espejados
- Sistemas en distintos Datacenter (Que estén en distintas ciudades)
- Failover de enlaces.

Dentro de los ataques que tenemos contra la disponibilidad tenemos:

- SYN FLOOD
- ICMP FLOOD
- UDP FLOOD
- DOS (Denial Of Service)
- DDOS (Distributed Denial Of Service). (Cortes Robles, 2016, <https://bit.ly/31zBkrH>)

Pregunta

Los tres pilares de la tríada de la seguridad son: disponibilidad, integridad y estandarización de seguridad.

Verdadero

Falso

Justificación

Tema 2. Comprensión de objetivos de negocio y procesos críticos asociados

Durante los últimos veinte años, las organizaciones de todos los tamaños han sido sostenidas por sus sistemas de información y sus gastos se han enfocado en gran medida en la intensificación de las infraestructuras de tecnología de la información. Esto con el fin de utilizar las tecnologías informáticas para su beneficio, manipular y analizar sus operaciones comerciales y estrategias a largo y corto plazo de una manera altamente profesional. Es difícil imaginar empresas contemporáneas desprovistas de sistemas de información avanzados, cubriendo sus operaciones diarias tales como comercio en línea, reservas de aerolíneas, bases de datos financieras, etcétera.

Los gerentes identifican que un desastre puede ocurrir como resultado de varias causas, dependiendo de una variedad de desafíos ambientales, económicos y políticos, como cortes de energía, erupciones de virus, interrupciones, fraude de datos, ataques terroristas y similares. Todo

ello puede disuadir a las organizaciones de ejercer su derecho a utilizar los datos y sistemas que necesitan para administrar sus negocios. Un análisis de impacto empresarial (BIA) puede exponer con precisión los perjuicios del desastre y las consecuentes interrupciones en un negocio específico. Sin embargo, estos tipos de análisis son costosos y muchos altos directivos no están dispuestos a brindar apoyo financiero basado en un análisis BIA sin una evaluación precisa al valor exacto o al retorno de la inversión (ROI).

La planificación de recuperación ante desastres (DRP) es una descripción de cómo reacciona una empresa ante cualquier evento interno o externo, asegurando que las operaciones comerciales críticas se desarrollen sin barreras. El objetivo del DRP es reducir las consecuencias de un desastre y realizar las acciones adecuadas para defender recursos valiosos. Por otra parte, Business Continuity Planning (BCP) ilustra los métodos y procedimientos que han sido utilizados por las empresas para garantizar que las funciones importantes continúen durante y después de un desastre, es la facilidad de sostener la disponibilidad continua de sistemas, aplicaciones e información importantes del negocio. BCP corresponde a la reacción de la comprensión empresarial requerida a los eventos indeseables. Este proceso debe ser logrado en las funciones de toda la empresa para reducir las pérdidas financieras, mejorar el servicio al cliente y aliviar los eventos destructivos que pueden afectar el nombre, los procesos, la liquidez y la reputación del mercado. Como resultado, la recuperación ante desastres, que se centra en las actividades de TI, es posiblemente la más común, sin embargo, es un subconjunto del tema más amplio de la continuidad del negocio. Mientras que la recuperación ante desastres es una reacción a eventos inusuales que elimina todo el desorden para que el negocio pueda continuar de forma normal, la continuidad del negocio es altamente proactiva, tiene planes, realiza acciones para garantizar que independientemente de lo que ocurra, las operaciones comerciales continúen tan estables como sea posible.

Veamos estos procesos en detalle.

Business Continuity Planning

Este concepto corresponde al proceso que se encarga de gestionar los recursos requeridos para permitir conseguir los objetivos de operación continua de un negocio. Dentro de los recursos se deben integrar la gestión de riesgos, la gestión de procesos, la gestión de sistemas informáticos y su infraestructura, la gestión de recursos físicos y humanos. Todos en su conjunto con el objetivo de mantener la continuidad de la operación del negocio, que es el objeto de la institución.

Este proceso está estandarizado en la norma internacional ISO 22301, la cual establece requisitos para implementar y mantener un sistema de gestión de continuidad del negocio (SGCN) ante interrupciones o desastres.

Figura 4: Business Continuity Planning



Fuente: elaboración propia en base a Mathenge, 2020, shorturl.at/xISY8

Business Continuity Plan

Un plan de continuidad de negocio, o BCP por sus siglas en inglés, es el proceso que permite a una organización mantener la continuidad operacional y comercial frente a la ocurrencia de algún tipo de desastre. Es uno de los entregables más importantes del *Business Continuity Planning*, proceso que busca generar dicho plan. Este documento contiene políticas, procedimientos y protocolos para reaccionar ante la ocurrencia del evento catastrófico. Además, brinda directrices para apoyar en la recuperación parcial o total de los procesos interrumpidos por dicho siniestro o evento.

Escenario catastrófico

Es un evento o conjunto de eventos que se consideran una catástrofe por sus efectos en la operación de una organización. Es propio del objetivo de la entidad, de su entorno y de sus condiciones operacionales.

Business Continuity Management System

Sistema de gestión de la continuidad del negocio o BCMS por sus siglas en inglés. Es un sistema que tiene por finalidad potenciar la capacidad de la respuesta de la organización frente a eventos catastróficos que interrumpa la normal provisión de productos y servicios, mediante la implementación de planes de acción denominados planes de continuidad del negocio (*Business Continuity Plan*) explicados anteriormente, salvaguardando, en primer lugar, el bienestar personal, la rentabilidad económica, la imagen, la reputación y las actividades de creación de valor.

Disaster Recovery Plan (DRP)

Es un plan que se hace cargo de las acciones, procedimientos, recursos y organización que prepara en la respuesta ante la ocurrencia de un desastre. Su objetivo directo es la supervivencia de una organización en una catástrofe. Habitualmente se asocia DRP con la recuperación de la operatividad de la tecnología y los sistemas, pero en un enfoque más amplio debe incorporar todos los ámbitos del negocio.

Business Resumption Planning (BRP)

Es la gestión de un plan para la reanudación de los procesos afectados por un evento catastrófico o por una falla de la plataforma informática.

Emergency Response Planning (ERP)

Es la gestión de un plan para salvaguardar a los empleados, al público, al entorno, al ambiente y a los bienes de la organización frente a una catástrofe.

La gestión de continuidad operacional es muy importante, por lo que ha llegado a convertirse en una disciplina profesional, que permite, además, formarse como especialista certificado en continuidad operacional, para desenvolverse específicamente en este ámbito.

El tema de la continuidad operacional ya ha sido ampliamente aceptado como parte de la estrategia empresarial, ya que existen normas internacionales que dan cuenta de ello. A continuación, mencionaremos las más importantes.

ISO 22301:2012

La ISO sobre Sistema de Gestión de la Continuidad de Negocio fue publicada en noviembre del 2019 y tiene por objetivo establecer un marco de buenas prácticas que buscan apoyar a las organizaciones a gestionar el impacto que podría tener una interrupción en el funcionamiento. Las ISO, en su mayoría, contemplan un período de transición de tres años para nuevas actualizaciones

Business Impact Analysis (BIA)

El *Business Impact Analysis* es la base de cualquier estrategia de continuidad del negocio. El BIA se usa para definir cuáles son los procesos y funciones que son críticos para la continuidad del negocio. Esto que pareciera tan evidente y trivial de realizar es, en realidad, un análisis de mayor importancia para resolver las preguntas: ¿cómo debo orientar los recursos, siempre escasos, para

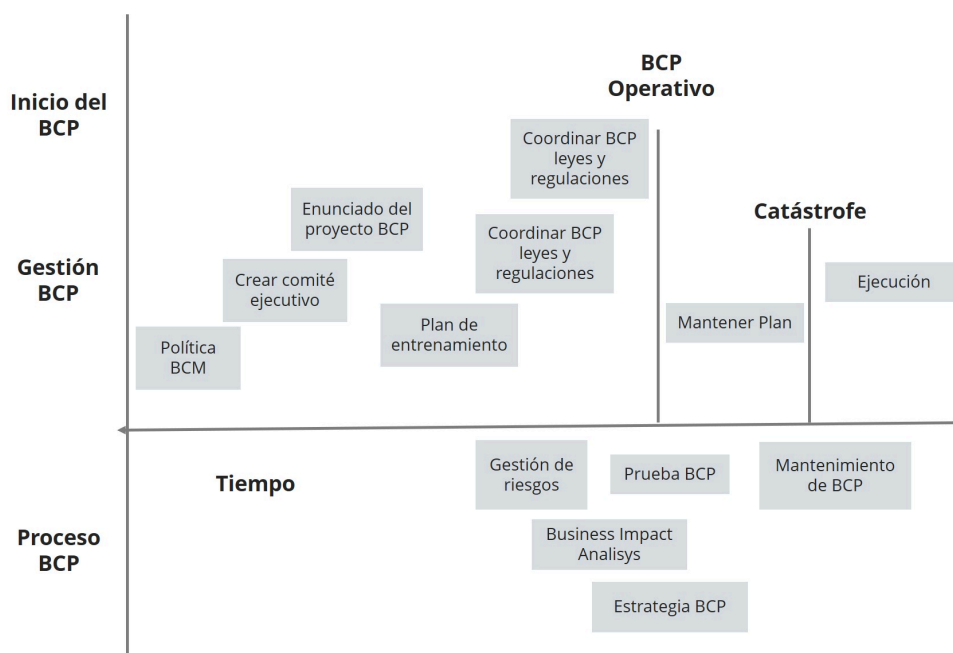
mejorar mi continuidad operacional? ¿Invierto en más maquinaria industrial o contrato un servicio de respaldo de mis sistemas informáticos (y cuál de ellos respaldo)? Las organizaciones tienen muchos procesos y funciones, pero solo algunos de ellos serán críticos y son precisamente estos a los que les debemos orientar los recursos disponibles y desarrollar un plan de continuidad de negocio (BCP).

Proyecto de BCP

Como pudiste observar con lo antes señalado, el desarrollo de un BCP es un proyecto que tiene luego una mantención en la que se deberá mejorar continuamente el plan. Para desarrollar este plan, debemos poner en marcha un proyecto que nos dará como entregable principal el BCP y un DRP, además de una serie de otros entregables.

La gestión del BCP y el proceso del BCP se reflejan en el siguiente cuadro, que nos permite visualizar el camino para disponer y mantener un BCP para nuestra organización.

Figura 5: Gestión y proceso del BCP



Fuente: elaboración propia

Pregunta verdadero o falso

El enfoque más importante de un DRP (Disaster Recovery Plan) es que la organización pueda identificar un incidente catastrófico.

Verdadero, ya que no es necesario que el enfoque de DRP deba garantizar la recuperación y restablecimiento de la infraestructura y procesos de TI, que soportan sus procesos críticos primero, pero también de negocio.

Falso, ya que el enfoque de DRP debe garantizar la recuperación y restablecimiento de la infraestructura y procesos de TI, que soportan sus procesos críticos primero, pero también de negocio.

Justificación

Tema 3. Políticas Seguridad

Las políticas de seguridad informática se definen como una serie de normas y directrices que garantizan la confidencialidad, integridad y disponibilidad de la información de la infraestructura informática.

¿Qué son las políticas de seguridad informática?

Una política de seguridad se define como todo aquello que se debe proteger y cómo hacerlo, es decir, corresponde al conjunto de controles que deben implementar las organizaciones para proteger cualquier activo en ella. Las políticas de seguridad utilizan una serie de procedimientos e instrucciones técnicas que recogen las medidas técnicas y organizativas que se establecen para dar cumplimiento a dicha política.

Las definiciones de las políticas de seguridad se basan en la **identificación y el análisis previo de los riesgos** a los que está expuesta la información de la organización y debe incluir todos los procesos, sistemas y personal de la empresa. Toda política debe ser aprobada por la dirección de la organización o “alta gerencia” y comunicada **a todo el personal que trabaja en ella**.

Importancia de las políticas de seguridad informática, ¿para qué son?

Las políticas de seguridad nacen para el apoyo, respuesta y directrices de los diferentes riesgos de seguridad a los cuales una organización puede estar, por ejemplo:

- privacidad de la información y su protección frente a los accesos no autorizados tanto internos como externos;
- integridad de los datos, protección frente a posibles fallos informáticos o borrado de la información;
- disponibilidad de los servicios críticos de la organización frente a fallos externos o internos.

El objetivo de las políticas de seguridad es proporcionar a todo el personal de la organización y a todo quien accede o deba interactuar con los activos tecnológicos e información, las pautas a seguir para proteger los datos o contenido crítico. Estas políticas son muy necesarias al momento

de realizar futuras auditorías en las organizaciones.

Características de las políticas de seguridad informática

Durante tu trayecto en el mundo de la seguridad, te topará con diferentes tipos de políticas de seguridad que se implementan en las organizaciones, algunas pueden variar dependiendo el rubro o la legislación vigente de cada país. Además, es importante señalar que, en cada una de estas políticas, se establecerán objetivos y prioridades.

Todas las buenas políticas tienen características en común, como por ejemplo, las siguientes.

- Deben poder implementarse a través de procedimientos, pautas y reglas.
- Es indispensable definir roles, responsabilidades y obligaciones para los diferentes profesionales dentro de una organización, considerando al máximo de ellos, desde los cargos gerenciales hasta los administrativos.
- Su cumplimiento se debe respetar a cabalidad, para esto, se pueden controlar mediante el uso de herramientas de seguridad, amonestaciones o sanciones.

Utilizando los resultados de la evaluación y el análisis de riesgos, otras de las actividades que deben realizarse durante estas actividades conducirán a una elaboración correcta de una política de seguridad, la cual consiste en un documento donde se indica el compromiso y apoyo de la dirección, en el marco de la visión y misión de cada una de las organizaciones. Este documento explica la necesidad de seguridad de la información a todos los usuarios de la organización orientada a los recursos de la información.

Aspectos más relevantes que debe tener el documento

- Definición de seguridad para los activos de la información de la organización.
- Roles y responsabilidades.
- Planes y protocolos de contingencia.
- Gestión de contraseñas.
- Sistema de control de accesos.
- Respaldo o backups de datos.
- Manejo de amenazas e intrusiones.
- Inventario de activos.

Este documento, además, debe incluir el reporte de incidentes de seguridad, en el que se establecen lineamientos claros dentro de la política de seguridad de la organización.

Para la construcción de estas políticas de seguridad de la información dentro de la organización se debe contar con la participación de los colaboradores o miembros responsables, involucrando las actividades diarias que realizan cada uno en su entorno de trabajo.

Dado que las políticas de seguridad pueden afectar a todo el personal de una organización, es conveniente asegurar tener un nivel de autoridad alto o requerido para su establecimiento. Como ya mencionamos, las creaciones de las políticas de seguridad serán avaladas por la máxima dirección de la organización, quien tiene el poder de hacerlas cumplir. Una política que no se puede implementar y hacer cumplir en una organización es inútil.

Uno de los objetivos básicos en una implementación de políticas de seguridad consiste en definir qué se considera como uso apropiado de sistema informático, como también la forma como se tratarán los incidentes de seguridad. Para esto, se considerarán los siguientes criterios.

- Se debe tener en cuenta el objetivo social de la organización y sus características. Por ejemplo, la seguridad de una entidad bancaria es muy diferente a la de una universidad o institución educacional.
- Las políticas de seguridad que se implementen dentro de la organización deben estar relacionadas con las políticas, reglamentos, regulaciones y las leyes a las que está sujeta la organización.
- Se deben considerar las implicaciones de seguridad en un contexto más amplio. Las políticas deben manejar los asuntos derivados de un problema de seguridad que tiene causa de un sitio remoto, como también de un problema que ocurre dentro de la misma organización de un usuario o un computador local.

Antes de desarrollar las políticas de seguridad dentro de la organización se deben resolver todo tipo de interrogantes. A continuación, nombraremos algunos de estos interrogantes:

- ¿qué estrategia adoptará la organización para la gestión de seguridad de la empresa?
- ¿Qué activos tengo en mi organización?
- ¿Quiénes tendrán acceso a utilizar los activos informáticos?

- ¿Qué se entiende por uso correcto de recurso informático?
- ¿Dentro de la organización quién o quiénes se encuentran autorizados para garantizar el acceso y aprobación para la utilización de los activos informáticos?
- ¿Quién debería tener privilegios de administración de los activos informáticos?
- ¿Cuáles son los derechos y responsabilidades de los usuarios de la organización?
- ¿Cuáles son los derechos y responsabilidades de los administradores de activos informáticos frente a los usuarios?
- ¿Qué hacer con la información crítica, limitada y clasificada de la organización?
- ¿Qué hacer frente a un incidente de seguridad informática?

A medida que las organizaciones van formulando estos interrogantes, van surgiendo cada vez más, incluso con mayor importancia que otros, y deben ser incluidos y resueltos antes de comenzar con el desarrollo de una política de seguridad.

Principales características que debe tener una buena política de seguridad

- Poder implementarse a través de las medidas y procedimientos establecidos. Su publicación y principios deben ser de uso aceptable por la gerencia y, en lo posible, por un comité de seguridad de la información.
- Hacer cumplir estas políticas por medio de herramientas de seguridad. El no cumplimiento de esta puede derivar en sanciones.
- Definir roles y responsabilidades de usuarios, administradores y de la propia directiva.

Plan de trabajo para establecer políticas de seguridad.

- Agendar reuniones frecuentes con los responsables o jefes de los departamentos involucrados.
- Definir los alcances de pérdida de información.
- Definir las buenas prácticas en la manipulación de los datos en la red de la organización.
- Definir en la reunión las medidas de seguridad aplicadas al personal responsable dentro de la organización.
- Ejemplo de medidas de seguridad:

1. acceso a internet;
2. respaldo de información;
3. creación de perfiles de acceso a seguridad;
4. definición de permisos de acceso de escritura, lectura de recursos compartidos en la organización, según sea el perfil de acceso.

Buenas prácticas

Con respecto a las buenas prácticas de seguridad de la información, estas pueden ser un documento específico, cláusulas anexas a los contratos de los empleados, etcétera. Este documento debe especificar el uso aceptable de los sistemas y la información por parte del personal y debe ser comunicado, idealmente, al ingresar a la organización. Además, debe contener las directrices para el uso de activos dentro de la empresa, las especificaciones sobre políticas de contraseñas seguras y cifrado de información, lo cual debe acompañarse de talleres o charlas de concientización para crear una cultura de seguridad organizacional.

≡ Ejemplos de políticas de seguridad de la información

Como hemos revisado a lo largo del módulo, existen distintos tipos de políticas de seguridad que cambian en torno a quién va dirigida la política. En relación a esto, algunos ejemplos que podemos señalar son:

- política de contratos y ordenes de compras tecnológicas;
- política de privacidad de herramientas de trabajo;
- política de accesos y privilegios de los empleados;
- política de responsabilidad según cargo en la organización;
- política de disponibilidad de recursos informáticos;
- política de registro y notificaciones de violaciones y brechas de seguridad.

Activos de información

Un activo es un componente de un sistema de información susceptible de ser atacado deliberada o accidentalmente con consecuencias para la organización. Es decir, un tipo de

recurso que tiene un valor concreto (tangible o intangible) para una organización o Estado. Algunos de ellos son los siguientes:

- cualquier tipo de dato y/o información;
- servicios ofrecidos;
- aplicaciones informáticas;
- dispositivos electrónicos;
- elementos de red;
- recursos administrativos, físicos o humanos.

Por lo tanto, no debemos asumir que un activo simplemente es un computador o elemento tecnológico, hay varias otras opciones que hay que tener en mente.

Conclusión sobre las políticas de seguridad

Las políticas de seguridad son una herramienta fundamental para las empresas, en especial a la hora de concientizar al personal sobre los riesgos de seguridad que están vigentes día a día, lo que además nos proporciona pautas o protocolos de actuación concretos, tanto preventivas como reactivas. Sin embargo, para que sean efectivas, deberán tener las siguientes características.

- Confeccionarse mediante documentos que deben ser de conocimiento del personal que trabaja o trabajará en un futuro en la organización.
- Las políticas deben ser flexibles y periódicamente realizar revisiones y controles de estas, con la finalidad de adaptarse a los distintos cambios tecnológicos mundiales o a los objetivos actualizados de la empresa.
- Todo tipo de política, norma, reglamento, procedimiento, etcétera debe contar con el respaldo de la dirección, quien debe velar por el cumplimiento de esta; de otra forma su implementación podría verse afectada o no entregar los resultados esperados.

Pregunta verdadero o falso

Las políticas de seguridad informática se definen como una serie de normas y directrices que garantizan la confidencialidad, integridad y disponibilidad de la información

Verdadero.

Falso.

Justificación

Tema 4. Estándares y procedimientos de seguridad

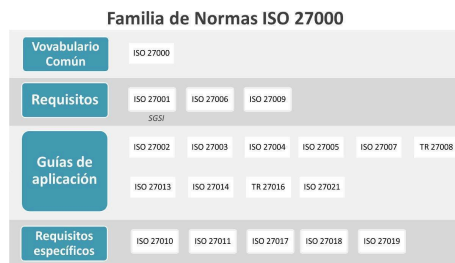
Las tecnologías de la información y comunicaciones han sido recursos esenciales para la productividad y competitividad de las empresas; sin embargo, como cualquier recurso, está inmerso en múltiples amenazas que se pueden materializar en un riesgo latente para las organizaciones.

Hoy en día las amenazas tecnológicas son parte de nuestro día a día y las más peligrosas pueden estar dentro de una organización, pasando por virus informáticos, ataques de denegación de servicio, ransomware, hasta ataques de día cero (Zero Day). Por esta razón, es muy necesario que las organizaciones puedan realizar implementaciones de control, con el objetivo de poder gestionar todo aspecto relacionado con la defensa, la protección y el cumplimiento de la legislación vigente.

La seguridad de la información corresponde a una disciplina asociada generalmente a la gestión de TIC, cuyo propósito es mantener los niveles aceptables del riesgo de la información organizacional y la de los activos tecnológicos que permiten su recolección, procesamiento, almacenamiento y distribución de estos. Para poder entender sobre estos aspectos, es que nace la familia de las normas ISO/IEC 27000 que buscan la preservación de la confidencialidad, integridad y disponibilidad de la información.

La adaptación temprana en las organizaciones ha permitido que muchas de ellas gestionan su seguridad mediante la norma ISO 27001, dejando de manifiesto la importancia que tiene la seguridad de la información en el mundo. Al pasar los años, las certificaciones que son otorgadas por la Organización Internacional para Estandarización (ISO) han presentado un crecimiento exponencial. No obstante, las normas establecen el “deber ser” y no la forma de cómo se logra, por esto, son tan importantes las metodologías que permiten a las organizaciones poder orientar correctamente sobre cómo abordar este tipo de procesos, apoyados por normas internacionales.

Figura 6: Normas ISO



Fuente: "Referencias normativas ISO 27000", s. f., <https://bit.ly/3014dfH>

Estándares de seguridad de la información

Uno de los requisitos para implementar un Sistema de Gestión de Seguridad de la Información (SGSI, conjunto de políticas de administración de la información) en una organización es conocer qué tipo de estándares existen, conocer su estructura y las relaciones que tienen entre cada uno de ellos.

Las normas para implementar un conjunto de políticas de administración de la información corresponden a una serie de normas internacionales de la familia ISO/27000, correspondientes aproximadamente a 17 normas clasificadas en cuatro categorías.

- La norma que contiene el vocabulario se encuentra en la norma ISO/IEC 27000.
- La norma de requerimientos se encuentra en la norma ISO/IEC 27001 y la norma ISO/IEC 27006.
- Las normas guía, desarrolladas a través de 10 normas: ISO/IEC 27002, ISO/IEC 27003, ISO/IEC 27004, ISO/IEC 27005, ISO/IEC 27007, TR 27008, ISO/IEC 27013, ISO/IEC 27014, TR 27016, ISO/IEC 27032.
- Las normas para sectores específicos se encuentran en las normas ISO/IEC 27010, ISO/IEC 27011, TR 27015 y TS 27017.

A pesar de la cantidad de normas de la serie ISO/27000, las utilizadas para desarrollar una implementación de un SGSI en una organización se enmarcan en cuatro de ellas, como se puede observar en la imagen.

≡ Norma ISO/IEC 27001:2013

Su primera revisión se publicó en el año 2005 y fue desarrollada bajo la norma británica BS 7799-2. Esta corresponde a una norma internacional que especifica cuales son los requisitos para poder establecer una mejora continua dentro de las organizaciones y de sus sistemas de

gestión de seguridad. Este modelo de gestión de seguridad de la información es definido como un conjunto de normas que permiten implementar un sistema con una mejora continua de seguridad de la información. Su eje principal es proteger la confidencialidad, integridad y disponibilidad de la información de una organización, realizando una constante evaluación de riesgos e implementando su mitigación.

≡ Norma ISO/IEC 27002:2013

Esta norma, al igual que la 27001, es una norma internacional, siendo la evolución de la norma ISO 179999, que fue actualizada el año 2005 con el nombre ISO 27002. El estándar de seguridad de la información de esta norma proporciona una diversidad de recomendaciones sobre las mejores prácticas en la gestión de la seguridad de la información. Una de sus características es establecer estándares, guías y recomendaciones relacionadas con el sistema de gestión, aplicadas a cualquier tipo de organización. Su estructura de los controles de seguridad de la información se encuentra conformada por 14 dominios, 35 objetivos de control y 114 controles, los cuales se encuentran divididos entre controles organizacionales, controles técnicos y controles normativos.

≡ Norma ISO/IEC 27003:2010

Esta norma, denominada formalmente como Tecnología de información - Técnica de seguridad - Guía de implementación de un sistema de gestión de seguridad de la información, tiene como objetivo el establecimiento de las especificaciones y diseño de un SGSI, el cual será el referente para esta propuesta metodológica.

≡ Norma ISO/IEC 27005: 2008

La norma ISO 27005 corresponde a un estándar internacional que proporciona directrices para la gestión de los riesgos relativos a la seguridad de la información, siendo su función principal el proporcionar directrices para la gestión de riesgos de la seguridad de la información. Esta norma es aplicable a todas las organizaciones que deseen gestionar los riesgos de seguridad de la información de la organización.

Su aplicación permite identificar, analizar, evaluar y tratar los riesgos que puedan afectar la

confidencialidad, integridad y disponibilidad de la información. Está diseñada para complementar la norma ISO/IEC 27001, ofreciendo un enfoque sistemático para la gestión del riesgo dentro del SGSI.

En este marco, la norma establece un constante monitoreo de los riesgos, ya que estos cambian constantemente y no se deben descartar las posibilidades de nuevos riesgos que afecten la integridad del negocio. Por esta razón, los riesgos deben ser supervisados y revisados de manera periódica con el fin de poder mitigar cualquier impacto. Entre los beneficios más importantes de esta norma, podemos encontrar la mejora continua, la estimulación de gestión proactiva de la organización, la mejora de controles internos, la mejora de seguridad y la confianza, entre otras.

ITIL

Information Technology Infrastructure Library (Biblioteca de Infraestructura de Tecnologías de información) es uno de los marcos de trabajo y referencia de buenas prácticas más utilizado a nivel mundial; cuenta con más de 2 millones de certificados dentro de las organizaciones. A diferencia de las normas, ITIL es una certificación para empleados y no para las empresas. Esta norma surge a fines del año 1989 y, entre los años 1990 y 1999, ITL –en su primera versión– estableció estándares más amplios de mejores prácticas en TI. Entre los años 2000 y 2007 se lanza su versión dos, siendo muy popular entre las certificaciones y accesible entre los empleados de TI. Ya en el año 2018 se actualiza a su versión número 3, adoptando un enfoque de ciclo de vida del servicio para la integración empresarial de TI. En esta versión se establecen 5 etapas de ciclo de vida, que son las siguientes:

1. estrategia del servicio;
2. diseño del servicio;
3. transición del servicio;
4. operación del servicio;
5. mejora continua del servicio.

Desde el año 2019, y hasta la actualidad, nos encontramos con la actualización en su versión 4, en donde el enfoque va más orientado a las mejores prácticas de interconexión de las organizaciones y las renovaciones digitales de estas. En esta versión se cambia la palabra proceso a práctica, se actualizan los sistemas del valor del servicio en TI. Esta actualización

cuenta con 14 prácticas de gestión, 17 prácticas de gestión de servicio y 3 prácticas de gestión técnica, siendo un total de 34 prácticas.

COBIT

COBIT (*Control Objectives for Information and Related Technology*) fue desarrollado por ISACA (*Information Systems Audit and Control Association*), que es una asociación internacional de miembros profesionales para personas u organizaciones en los campos de auditoría de TI. Es el marco de gobierno y gestión más utilizado en TI a nivel mundial.

COBIT es una guía de buenas prácticas presentadas como framework dirigida al control y supervisión de las tecnologías de la seguridad de la información. Es un marco de referencia para los gobiernos de gestión de la información y la tecnología de las organizaciones, haciendo una distinción clara entre gobierno y la gestión propiamente dicha.

Fue fundada el año 1967 y se ha convertido en una organización reconocida internacionalmente y, en la actualidad, cuenta con más de 150 000 miembros a lo largo del mundo. COBIT se desarrolló inicialmente para apoyar a los profesionales de auditoría financiera, quienes se veían enfrentados a escenarios automatizados. ISACA lanzó su primera versión en el año 1996, en el marco de ejecución de tareas de auditoría de TI. Esta edición fue rápidamente reemplazada por la segunda edición en 1998, que se construyó en torno a un conjunto integral de objetivos de control para los procesos de TI. Su tercera versión fue lanzada en el año 2000, en donde se incorporaron pautas de gestión, métricas, factores críticos de éxito y modelos de madurez para los procesos de TI. En el año 2005, ISACA lanzó COBIT 4.0, la cual introdujo nuevos sistemas de administración y conceptos de gobernanza. El propósito de esta cuarta edición fue establecer aún más COBIT como un marco generalmente aceptado para el gobierno de TI.

El sucesor de COBIT 4.0 fue lanzado el año 2007 nombrado como COBIT 4.1. Los marcos de Val IT y Risk IT abordaron los procesos comerciales relacionados con TI y responsabilidades en la creación de valor y la gestión de riesgos, respectivamente.

En noviembre de 2018, se lanzó oficialmente el sucesor de COBIT 5, es decir, COBIT 2019. Este se desarrolló en base a dos grupos de principios, los cuales describen los requisitos fundamentales de un sistema de gobierno para la información y tecnología de una empresa. Otro marco principal es el que hace referencia a los requisitos que debe tener un sistema de gobierno,

los cuales nombramos a continuación.

Principios para un sistema de gobierno

Existen seis principios para un sistema de gobierno:

1. proporcionar valor a las partes interesadas;
2. enfoque holístico;
3. sistema de gobierno dinámico;
4. diferenciar el gobierno de la gestión;
5. adaptarse a las necesidades de la empresa;
6. sistema de gobierno íntegro.

Unidad 2. Políticas de seguridad de personal

Tema 1. Políticas de Seguridad para el personal. Descripción de roles y responsabilidades.

Como se mencionó en la unidad anterior, existen diferentes políticas que debemos establecer para poder regular la seguridad de la información de nuestras organizaciones. Si bien todas tienen aspectos diferentes a evaluar, cada una de ellas es importante para mejorar los procesos, tanto desde el punto de vista de la seguridad interna como externa.

Una política de seguridad de personal es un documento donde se detallan los lineamientos para la correcta protección de datos personales por parte de los empleados, sus responsabilidades con la organización y el cuidado que se debe tener respecto a riesgos y amenazas, tanto para la empresa como para sus intereses personales, entre otros factores de interés para la alta gerencia. Es importante señalar que no solo debe centrarse en la organización, también es necesario preparar, capacitar y educar a los trabajadores en temas de seguridad que puedan ser de utilidad para sus vidas.

Roles y responsabilidades en seguridad de la información

Este es uno de los temas más importantes para ejercer un sistema de seguridad de la información. Muchas veces, las organizaciones descuidan este punto y no existen lineamientos claros para establecer directrices.

El buen desempeño del SGSI se ve afectado cuando una organización no asigna roles y responsabilidades para las diferentes actividades asociadas a esta labor, por eso, es necesario enfatizar en que la alta dirección tiene que liderar permanentemente el sistema de gestión de seguridad de la información. Para poder liderar se requiere entender qué es un SGSI y los problemas asociados a su implementación, entre otros. Además, el explicar estas políticas es una actividad que debe realizarse siempre, en especial al momento de contratar nuevos trabajadores; si el personal de una organización no asume sus roles, responsabilidades y autoridades, es porque probablemente no entienden las políticas y procedimientos.

El SGSI debe partir desde la alta dirección hacia abajo, si esto se desarrolla desde niveles diferentes, probablemente existan problemas en el futuro.

La norma ISO 27001, en su cláusula 5.3 sobre roles, responsabilidades y autoridad, señala que la alta gerencia es la encargada de asignar y comunicar las responsabilidades y autoridades para todos los roles relacionados con la seguridad de la información. Esto tiene por finalidad:

- asegurar que el SGSI esté conforme a los requisitos de esta norma internacional;
- reportar sobre el desempeño del SGSI a la alta gerencia.

Otro aspecto importante es la segregación de tareas; una persona no puede ser juez y parte de unos mismos procesos, tantos los deberes como las áreas de responsabilidades en conflicto deben segregarse para reducir las oportunidades de modificación o mal uso no autorizado de los activos de la empresa, como también daños no intencionales que podrían causar problemas.

Proceso de asignación de roles, responsabilidades y autoridad

Para definir bien esta tarea, es necesario establecer un proceso, que se define a continuación.

Figura 7: Proceso de asignación de roles, responsabilidades y autoridad



Fuente: elaboración propia.

En la primera parte debemos definir, por ejemplo: ¿quiénes componen la alta dirección? ¿Quién es el director ejecutivo de la seguridad de la información? ¿Quién será el gestor de la seguridad de la información? ¿Quiénes serán los responsables de los riesgos? ¿Quiénes serán los responsables de los controles y quienes implementaran?, etcétera. Todo esto debe estar alineado a la parte orgánica de la empresa.

Lo anteriormente expuesto debe estar escrito para que un trabajador conozca sus funciones y no reniegue de ellas. Idealmente, este tipo de acuerdos deben estar en algún documento contractual que haga referencia a sus funciones, deberes y responsabilidades.

Algunos roles que podrían definirse por parte de la gerencia, la cual, recordemos, es responsable de aplicar y gestionar las políticas y procedimientos establecidos en la organización, pueden ser:

- rol: alta gerencia o dirección. Cargo: directorio;
- rol: director ejecutivo o CEO. Cargo: gerente general;
- rol: oficial de seguridad o CISO. Cargo: gerente de seguridad;
- rol: responsables de riesgo. Cargo: gerencias;
- rol: responsable de controles. Cargo: subgerencias o jefaturas;
- rol: responsable de implementación de controles. Cargo: subgerencias o jefaturas;
- rol: operador de controles. Cargo: subgerencias o jefaturas;
- rol: operador de monitoreo. Cargo: subgerencias o jefaturas;
- rol: responsable de activos. Cargo: subgerencias o jefaturas;
- otros definidos por la alta gerencia.

Para asignar estos roles, hay que tener en cuenta en qué niveles serán designados, por ejemplo, una composición jerárquica de una organización podría ser la siguiente.

Finalmente, es importante tener en cuenta que la alta gerencia siempre debe tomar conciencia y liderar adecuadamente en la designación de roles, responsabilidades y autoridad. Esta tarea clave en todo el proceso puede beneficiar en mejorar cada actividad futura, considerando la capacidad de personal, las competencias profesionales y el marco de trabajo para llevar a cabo un sistema de gestión de seguridad de la información.

Al momento de contratar a un nuevo empleado o realizar cualquier acuerdo contractual que se lleve a cabo con algún proveedor o cliente, en nuestras políticas se debe estipular cuáles son las responsabilidades de todos estos actores, en relación a la seguridad de la información.

Cuando una persona cesa sus funciones en la empresa, a nivel de seguridad de la organización, debe mantener la confidencialidad de todo a lo que tuvo acceso o conocimiento, por un tema ético y, muchas veces, porque podría repercutir en temas legales si no se cumple a cabalidad.

Un punto importante en esta parte es el proceso de desvinculación. Probablemente pienses que este tipo de actividad no se realiza en las empresas y por desgracia, es verdad. No todas cuentan con un protocolo para que la desvinculación de un empleado sea paulatina, es decir, lo más perjudicial para ambas partes. Para poder realizar esto, se deben considerar los siguientes puntos.

- Definir plazos de entrega de responsabilidades.
- Quitar los privilegios a la documentación u activos cada vez que estos fueron entregados a la parte suplente o reemplazante.
- Controlar que tantas responsabilidades como activos y/o tecnologías que utilizaba la persona a desvincular sean traspasadas correctamente.
- Recordarle las políticas de seguridad de la información en cuanto a la confidencialidad de la información a la que tuvo acceso. Esta parte debe ser lo menos agresiva posible cuando el empleador es quien quiere la desvinculación.
- Actualizar o cambiar contraseñas que fueran utilizadas en activos de la empresa.
- Dar un tiempo para que la persona desvinculada pueda limpiar correos electrónicos o estaciones de trabajo siempre y cuando no sea necesaria para la organización, por ejemplo, conversaciones vía correo de índole personal, spam, etcétera.
- Entregar todo tipo de documentación generada durante su trabajo, ya sea en formato digital como físico.

Si bien esto puede sonar muy fácil, en la práctica dependerá de las condiciones de la desvinculación; lo importante es tener un protocolo de actuación ante estos casos, considerando que el activo más importante para una empresa son sus trabajadores.

Antes de implementar cualquier tipo de medida sobre educación y entrenamiento es necesario crear una cultura de seguridad. Este factor será clave para el éxito a nivel empresarial y, por sobre todo, uno de los más complejos para implementar, principalmente porque su foco son las personas no técnicas o no relacionadas con estas materias.

La empresa puede tener los mejores profesionales TI o de seguridad, pero no siempre se les da valor a estos temas y pasan desapercibidos, por eso hay que comunicar todas las acciones que se realizan a nivel de seguridad. Algunas ideas para levantar este tipo de campañas de concientización o sensibilización pueden ser las siguientes.

- Curso de capacitación de seguridad de la información para el personal de la organización.
- Charlas de expositores especialistas periódicamente.
- Revistas digitales evidenciando el impacto que el área de seguridad tiene en la organización.
- Videos cortos, al estilo de las redes sociales, para difundir en la organización señalando los riesgos del ciberespacio y cómo protegernos.
- Crear una semana de la seguridad en la empresa para debatir sobre estos temas.
- Estímulos o gratificaciones al “empleado con más cultura de seguridad”.
- Creación o materialización de un “escuadrón seguro”, donde participen trabajadores ajenos a las áreas de seguridad o tecnología.
- Designar un presupuesto anual para este tipo de actividades.
- Infografías o posters en los sectores más concurridos de la empresa, o correo electrónico con dicha información.

Tema 4. Privacidad

La privacidad es un derecho, todos pueden exigir que este derecho se cumpla. Pero, además de exigir, debemos tener en cuenta y ser conscientes de qué sucede con nuestra información cuando la compartimos libremente por diferentes medios. Si a eso le sumamos la privacidad que debe existir en actividades empresariales, se pone más interesante, ya que debemos tener en claro los diferentes aspectos que involucran la privacidad, tanto para la vida personal como para las organizaciones.

Privacidad de datos

La privacidad de datos antiguamente no era una necesidad para las organizaciones. Con el paso del tiempo, este tipo de situaciones referentes a privacidad fueron tomando fuerza debido a las diferentes filtraciones o data leaks de información que se difunden sin una autorización previa por parte de las empresas o las personas miembros de estas organizaciones. Por ejemplo, fugas de información médica, de redes sociales, de servicios de almacenamiento en la nube, entre muchos otros.

Figura 8: Redes sociales



Fuente: [Imagen sin título sobre redes sociales], s. f., <https://bit.ly/3wqkM0x>

Para poder comprender de mejor forma este tema, es importante explicar qué es la privacidad. Según la RAE, la privacidad es una “cualidad de privado” (o no público), y “ámbito de la vida privada que se tiene derecho a proteger de cualquier intromisión” (RAE, 2021, <https://bit.ly/30c7hFY>). En este sentido, mucha de nuestra información hoy en día es consumida por diversos medios digitales. Desde utilizar nuestro número de identificación para acceder a créditos en bancos, hasta aceptar las cookies al visitar un sitio web, todo de alguna forma almacena datos nuestros, que deben ser protegidos o resguardados con los más altos estándares de seguridad.

La protección de datos personales es una de las disciplinas del derecho informático, del derecho de la información, de los derechos humanos y del derecho constitucional. Estos buscan garantizar que la información almacenada, procesada o tratada por cualquier tipo de tecnología cumpla con la seguridad necesaria para su resguardo, evitando su divulgación o uso malintencionado de esta.

No todos los países tienen en su constitución el reconocimiento de esta protección como derecho humano, sin embargo, con el pasar de los años, es un tema que evoluciona y adquiere una real importancia. Esto no es solo para actividades del ámbito de la informática o similares, sino también se ha convertido en un debate profundo en cuanto a legislaciones en diversas naciones que buscan proteger este derecho a la privacidad de las personas.

La protección de datos personales se debe llevar a cabo mediante el uso de prácticas, resguardos

y principios fundamentales, los cuales deben ejecutarse para proteger la información personal y asegurar que el dueño de la información siempre mantenga un control sobre esta. Esto con la finalidad de que el creador o dueño de los datos personales tenga la facultad y la posibilidad de decidir, siempre y cuando lo desee, el compartir o no los datos que por derecho le pertenecen, además de decidir si un tercero puede acceder a esta información mediante una identificación y validación.

Producto de lo anterior, ya puedes identificar tres factores claves para la protección de datos personales:

- principios;
- dueño;
- control.

Si tienes Facebook, por ejemplo, eres el dueño de los datos y puedes compartir con quienes quieras la información que ahí se encuentra. La plataforma social es responsable de guardar tus datos de forma segura.

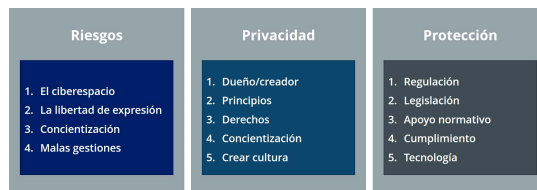
Riesgos de los datos personales

La información personal puede llegar a revelar antecedentes confidenciales o privados del propio creador o dueño de esta, la cual, en el peor de los escenarios, podría ser usada en su contra por delincuentes cibernéticos o de otra índole, lo cual es sumamente peligroso para casos de individuos o comunidades vulnerables, tales como activistas, agrupaciones de marginados, víctimas de delitos, pacientes con historia médica sensible, entre otros.

La información de datos personales debe estar protegida de la manera más estricta posible, esto se hace cada vez más difícil debido a la alta demanda de información que se transmite por diferentes sitios y con capacidad de visualizar o descargar de forma inmediata, donde las personas, creadores o dueños son los más afectados ya que pueden llegar a perder el control de su información personal. En esta parte es donde la protección de los datos entra en juego y las organizaciones que almacenan esos datos deben proteger la data.

En resumen, el tipo de factores que debemos tener en cuenta a partir de ahora, en relación a lo presentado hasta este momento, son los siguientes.

Figura 9: Factores a tener en cuenta



Fuente: elaboración propia.

Cuando hablamos de riesgo, una de las primeras consideraciones es el ciberespacio, lugar donde se encuentra la mayor cantidad de información y donde habitualmente subimos datos, ya sean fotos, comentarios y likes, entre otros. Aquí es donde debemos exigir que la información que suministramos en diferentes plataformas tenga medidas de seguridad para protegerla. Lamentablemente, existen otros factores externos que pueden afectar este proceso, como la libertad de expresión. Por ejemplo, si otro usuario de una red social decide escribir comentarios negativos acerca tuyo y lo complementa con imágenes privadas que pudo conseguir de otra fuente, esto de alguna forma te puede afectar, pero dicha persona también tiene derecho a expresarse; entonces entramos en una paradoja de nunca terminar ¿verdad? Por eso, es tan importante crear conciencia desde pequeños. Debemos enseñar sobre la relevancia de los datos personales, el cuidado que debemos tener al momento de subir información a la internet y, por sobre todo, cuidar la data que generan las organizaciones mediante su personal o por las actividades diarias.

Debemos tener en cuenta que no solo los cibercriminales tienen intenciones malas con nuestros datos, a veces podemos encontrarnos con personas que, por diferentes convicciones o venganza, pueden provocar daños o robar información confidencial. Estas personas son llamados Insiders y trabajan o tienen un alto conocimiento sobre la organización y abusan de estos privilegios para obtener, dañar o espiar dentro de la propia empresa, muchas veces por motivaciones económicas.

Protección de los datos en las organizaciones

Con la pandemia del covid-19, muchas empresas cambiaron su forma de trabajar y las personas tuvieron que adaptarse mucho más a la tecnología, lo cual no siempre significa avance. Este cambio propone nuevos desafíos que deben ser sorteados tanto por las organizaciones como por los trabajadores.

Para lograr dar seguridad o proteger los datos de manera adecuada, existen varias actividades

que pueden desarrollarse, algunas de ellas son básicas y otras más específicas, lo importante es comprender que este trayecto no se detiene. A continuación, mencionamos algunas actividades que se deben ejecutar para mejorar la seguridad o protección de datos.

≡ Clasificar los datos

determinar, en base a algún tipo de matriz, cuáles son críticos para las organizaciones, cuáles tienen un nivel más bajo, cuáles pueden ser de dominio público y cuáles son netamente confidenciales.

≡ Determinar dónde se almacenarán

es importante conocer la infraestructura donde se almacenaron los datos: en la nube, en un servidor propio, de manera local, etcétera. Independientemente de la selección, esta debe ser evaluada considerando los riesgos antes mencionados y el control de acceso a la información debe ser seguro no solo para un administrador, sino también para todo aquel que deba trabajar con dichos datos.

≡ Usar contraseñas robustas

no es seguro seguir utilizando passwords con pocos caracteres, ya que en la actualidad existen diferentes herramientas o técnicas para poder adivinar credenciales y, si estas son poco seguras, pueden identificarse en minutos.

≡ Utilizar métodos de autenticación

no basta con solo tener una contraseña, en lo posible se debe utilizar doble factor de autenticación para evitar que terceros tomen el control de cuentas, sistemas u otros.

≡ Parchado de *software*

identificar cuándo una versión de software se encuentra desactualizada y ejecutar el correspondiente proceso de parchado lo antes posible.

≡ Copias de seguridad (*backups*)

realizar copias de seguridad, en lo posible semanalmente, para evitar que la información pueda ser comprometida por amenazas extraordinarias, de esta forma no se pierde el trabajo de días, meses o años.

Video de habilidades

Glosario

Glosario Interactivo

 Buscar...

Business continuity planning

Centros de cómputo

Cifrar

Clústeres

Cookies

CPD

CSIRT

Códigos de fuente

Data leak

DDOS

Cierre

El mundo de la seguridad es enorme y es un lugar donde podemos ejercer diferentes disciplinas que trabajan en conjunto con un objetivo en común. Acabamos de conocer varios aspectos relacionados a la gestión de la seguridad, te invitamos a repasar los conceptos y poner en marcha tu camino como oficial de seguridad de la información.

Bibliografía

Álvarez Marañón, G. y Pérez García, P. P. (2004). *Seguridad informática para empresas y particulares*. Madrid, España: McGraw-Hill

Cabrera, J. I. (17 de enero de 2020). *El fastidio de la ciberseguridad moderna: recordar todas nuestras contraseñas*. En nobbot. Recuperado de <https://www.nobbot.com/pantallas/consejos-evitar-fatiga-de-la-contrasena/>

Cortes Robles, D. (3 de enero de 2016). *Fundamentos Básicos de Seguridad de la Información*. En Seguridad y Firewall. Recuperado de <https://www.seguridadyfirewall.cl/2016/01/fundamentos-basicos-de-seguridad-de-la.html>

Instituto Nacional de Ciberseguridad (Incibe). (s. f.). *Protección de la información*. Ministerio de Asuntos Económicos y Transformación Digital, Gobierno de España. Recuperado de https://www.incibe.es/sites/default/files/contenidos/dosieres/metad_proteccion-de-la-informacion.pdf

Information Security Management System (2022). Information security, cybersecurity and privacy protection — Information security management systems — Requirements. (ISO/IEC 27001). <https://www.iso.org/obp/ui/en/#iso:std:82875:en>

Information Security Management System (2019). *Security and resilience — Business continuity management systems — Requirements*. (ISO 22301). <https://www.iso.org/standard/75106.html>

Mathenge, J. (12 de agosto de 2020). *Business Continuity vs Business Resiliency: What's The Difference?* En bmc. Recuperado de <https://www.bmc.com/blogs/business-continuity-vs-resiliency/>

Real Academia Española (RAE). (2021). *Privacidad [Definición]*. En Diccionario esencial de la lengua española (23° ed.). Recuperado de <https://dle.rae.es/privacidad>

Referencias normativas ISO 27000. (s. f.). En ISO 27000. Recuperado de <https://normaiso27001.es/referencias-normativas-iso-27000/>

Seguridad Activa – Control de Redes. (10 de agosto de 2016). En *Mi Nube Informática*.

Recuperado de <http://minubeinformatica.com/cursos/seguridad-informatica/seguridad-activa-control-de-redes>

[Imagen sin título sobre redes sociales], s. f., <https://www.diariojuridico.com/wp-content/uploads/2017/12/redes-sociales-diario-juridico.jpg>

Descarga

A continuación, podemos descargar la lectura completa en su formato PDF y MP3.